

HOW TO IMPLEMENT ISO/IEC 27001

*A Practical Guide to Building, Operating, Auditing, and Improving an
Information Security Management System*

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Purpose and important notice

This manual provides practical implementation guidance for ISO/IEC 27001:2022 and its 2024 climate-action amendment. It does not reproduce the copyrighted standard and does not replace obtaining an authorized copy. Certification can only be issued by an accredited certification body after an independent audit.

Human safety comes first. Information security decisions should protect people, privacy, dignity, essential services, and lawful rights.

How to use this manual

- Use Chapters 1-5 to establish context, leadership, scope, and governance.
- Use Chapters 6-12 to assess risk, select controls, implement operations, and build evidence.
- Use Chapters 13-17 for internal audit, management review, corrective action, certification readiness, and continual improvement.
- Adapt every example to your organization, legal obligations, technology, and risk appetite.

Table of contents

- 1. Understanding ISO/IEC 27001
- 2. Implementation principles and project governance
- 3. Clauses 4-10 overview
- 4. Context and interested parties
- 5. ISMS scope
- 6. Leadership, policy, and roles
- 7. Risk assessment method
- 8. Risk treatment and Statement of Applicability
- 9. Annex A control themes
- 10. Documented information
- 11. Operational implementation and evidence
- 12. Competence, awareness, and communication
- 13. Performance monitoring and metrics
- 14. Internal audit
- 15. Management review
- 16. Nonconformity and corrective action
- 17. Certification readiness
- 18. 30/60/90-day roadmap
- 19. Templates and checklists
- 20. Glossary and official references

1. Understanding ISO/IEC 27001

ISO/IEC 27001 specifies requirements for an information security management system (ISMS). The ISMS is a managed system of policies, processes, responsibilities, risk decisions, controls, evidence, monitoring, and improvement. It is not merely a control checklist or a technology project.

Concept	Practical meaning
ISMS	The governance and operating system used to manage information-security risk.
Risk-based approach	Controls are selected and justified according to risk, obligations, and context.
Annex A	A reference set of controls used during risk treatment and Statement of Applicability development.
ISO/IEC 27002	Implementation guidance for information-security controls; it is not the certification requirements standard.
Certification	Independent confirmation that the ISMS conforms to the requirements within a defined scope.

Current edition note

ISO/IEC 27001:2022 is the current requirements edition. Amendment 1:2024 adds climate-action considerations to the management-system context and interested-party requirements. Organizations should determine whether climate change is relevant to the ISMS and whether interested parties have climate-related requirements.

2. Implementation principles and project governance

- Treat implementation as a business-change program, not a documentation exercise.
- Obtain executive sponsorship and define decision authority.
- Use a cross-functional team that includes security, IT, privacy, legal, HR, procurement, facilities, operations, and business owners.
- Build the ISMS around real processes already used by the organization.
- Create evidence as work is performed rather than immediately before an audit.
- Avoid claiming a control operates effectively until objective evidence supports the claim.

Role	Typical accountability
Executive sponsor	Resources, priorities, risk acceptance, management support.
ISMS manager	Implementation plan, coordination, documentation, metrics, audit readiness.
Risk owners	Evaluate and accept or treat risks.
Control owners	Design, operate, monitor, and improve assigned controls.

Internal auditor	Independently evaluates conformity and effectiveness.
Employees and contractors	Follow requirements, report events, and complete training.

3. Clauses 4-10 overview

Clause	Implementation focus
4 Context	Organization, interested parties, scope, ISMS processes.
5 Leadership	Commitment, policy, roles, accountability.
6 Planning	Risks, opportunities, objectives, risk assessment and treatment.
7 Support	Resources, competence, awareness, communication, documented information.
8 Operation	Operate planned processes, assessments, treatment, and change controls.
9 Performance evaluation	Monitoring, measurement, internal audit, management review.
10 Improvement	Nonconformity, corrective action, continual improvement.

4. Context and interested parties

- Identify internal issues: strategy, structure, culture, technology, staffing, dependencies, prior incidents, and risk appetite.
- Identify external issues: laws, regulators, customers, suppliers, threat environment, market expectations, geography, and climate-related disruption where relevant.
- Identify interested parties and their information-security requirements.
- Record which requirements become binding obligations for the ISMS.
- Review context after major changes and at planned intervals.

Interested party	Possible requirement
Customers	Confidentiality, availability, breach notification, audit rights.
Regulators	Security safeguards, records, reporting, data-location rules.
Employees	Secure access, privacy, usable procedures, awareness.
Suppliers	Clear security clauses, access boundaries, incident coordination.
Executive leadership	Risk visibility, resilience, lawful operation, cost control.
Communities and essential-service users	Continuity, safety, accessibility, responsible

	incident handling.
--	--------------------

5. ISMS scope

The scope defines what the ISMS covers and therefore what a certification statement may describe. It should be understandable, defensible, and aligned with real organizational boundaries and dependencies.

- Define products, services, processes, locations, systems, people, and legal entities included.
- Document interfaces and dependencies with excluded areas.
- Do not exclude a process merely because it is difficult to secure.
- Ensure the scope reflects customer and regulatory commitments.
- Publish and control the scope as documented information.

Example scope: *The ISMS covers the design, development, hosting, support, and corporate functions supporting the Acme SaaS platform from the Bogotá and remote-work environments, including Azure production services and approved third-party providers.*

6. Leadership, policy, and roles

- Approve an information-security policy aligned with purpose and risk.
- Set measurable security objectives.
- Assign authority and responsibility for ISMS processes.
- Integrate security requirements into business operations and projects.
- Provide resources and remove obstacles.
- Promote reporting without retaliation and support continual improvement.

Policy content

- Purpose and commitment
- Applicability
- Security principles
- Compliance with obligations
- Risk management
- Roles and responsibilities
- Incident reporting
- Exceptions and enforcement
- Review and approval

7. Risk assessment method

The organization must define and apply a repeatable information-security risk-assessment process that produces consistent, valid, and comparable results.

Step	Expected output
------	-----------------

Establish criteria	Likelihood, impact, risk acceptance, assessment frequency.
Identify risk	Assets or processes, threats, vulnerabilities, consequences, owners.
Analyze risk	Inherent likelihood and impact; existing-control effectiveness.
Evaluate risk	Comparison with acceptance criteria and priorities.
Record results	Approved risk register with traceable decisions.

Sample 5x5 criteria

Score	Likelihood	Impact
1	Rare	Negligible disruption or loss.
2	Unlikely	Limited operational or financial effect.
3	Possible	Material effect requiring management attention.
4	Likely	Serious legal, operational, safety, or customer effect.
5	Almost certain	Severe or sustained impact, major harm, or existential consequence.

A numeric matrix supports consistency but does not replace professional judgment. Document assumptions, uncertainty, and the reason for material ratings.

8. Risk treatment and Statement of Applicability

- Choose treatment: modify, avoid, share/transfer, or retain.
- Identify necessary controls from Annex A and other sources.
- Compare selected controls with Annex A to ensure no relevant control was missed.
- Create the Statement of Applicability (SoA).
- Document justification for inclusion and exclusion.
- Define owners, resources, deadlines, and residual-risk approval.
- Obtain risk-owner acceptance before treatment closure.

SoA field	Example
Control reference	A.5.15 Access control
Applicable	Yes
Justification	Required to reduce unauthorized-access risk and meet customer obligations.
Implementation status	Implemented / Partially implemented / Planned
Control owner	Director of IT

Evidence	Access policy, role matrix, quarterly review records.
Exclusion rationale	Only when not applicable, with defensible context and risk reasoning.

9. Annex A control themes

The 2022 Annex A contains 93 controls organized into four themes. The organization is not required to implement every control blindly; it must determine necessary controls through risk treatment and justify decisions in the SoA.

Theme	Examples
Organizational	Policies, roles, threat intelligence, supplier security, incident management, continuity, compliance.
People	Screening, terms of employment, awareness, disciplinary process, remote work, event reporting.
Physical	Perimeters, entry controls, equipment protection, clear desk, media, utilities, disposal.
Technological	Identity, authentication, malware protection, logging, cryptography, network security, secure development, cloud-service use.

Control implementation record

- Control objective and risk addressed
- Owner and operators
- Procedure or technical configuration
- Frequency or trigger
- Inputs and outputs
- Evidence location and retention
- Exceptions and escalation
- Effectiveness measure
- Review date

10. Documented information

Documents explain what should happen; records show what did happen. Both must be controlled.

Document or record	Examples
Required core documents	Scope, policy, risk methodology, risk results, treatment plan, SoA, objectives.
Operational procedures	Access, change, incident, backup, supplier, secure development, continuity.

Records	Training, approvals, reviews, logs, tests, incidents, audits, management review.
Control requirements	Approval, version, owner, access, retention, change history, disposal.

11. Operational implementation and evidence

- Translate controls into routine tasks with owners and frequencies.
- Integrate security into onboarding, procurement, changes, development, operations, and offboarding.
- Define evidence before a control begins operating.
- Use system-generated evidence where reliable and protected.
- Retain complete populations for sampled controls.
- Review exceptions and failed activities instead of hiding them.
- Control outsourced processes and verify supplier performance.

Evidence quality test

- Relevant: proves the specific control activity.
- Reliable: comes from a trustworthy source.
- Complete: covers the required period and population.
- Traceable: identifies date, owner, system, and approval.
- Protected: access and retention are controlled.

12. Competence, awareness, and communication

- Define competence requirements for security-relevant roles.
- Evaluate experience, training, certifications, and observed performance.
- Provide role-based education, not only annual general awareness.
- Retain evidence of competence and training.
- Ensure personnel understand the policy, their contribution, and consequences of nonconformity.
- Define what, when, with whom, and how the organization communicates security matters.

13. Performance monitoring and metrics

Metric	What it can show
Critical vulnerabilities past SLA	Exposure and remediation discipline.
Privileged access reviewed on time	Access-governance operation.
Backup restoration success	Recoverability, not only backup completion.
Supplier reviews completed	Third-party governance coverage.
Incidents detected and contained	Detection and response capability.
Corrective actions overdue	Weakness in improvement discipline.
Security objectives achieved	Progress against planned outcomes.

Every metric should have an owner, source, calculation, target, frequency, audience, and action when outside tolerance.

14. Internal audit

Internal audits determine whether the ISMS conforms to organizational requirements and ISO/IEC 27001 and whether it is effectively implemented and maintained. Auditors should be objective and independent of the work they audit.

- Create a risk-based audit program covering all clauses and relevant controls over a planned cycle.
- Define scope, criteria, methods, responsibilities, and reporting.
- Review documents and sample records.
- Interview personnel and observe operations.
- Record conformities, nonconformities, observations, and evidence.
- Track corrective actions to verified closure.

Finding element	Required quality
Requirement	Exact internal or standard requirement being evaluated.
Objective evidence	Specific record, observation, interview, or configuration.
Statement	Clear description of the gap without unsupported opinion.
Risk or effect	Why the gap matters.
Owner and due date	Accountable remediation commitment.

15. Management review

- Status of prior actions
- Changes in context and interested-party requirements
- Information-security performance and trends
- Audit results
- Achievement of objectives
- Feedback from interested parties
- Risk assessment and treatment status
- Opportunities for continual improvement
- Resource and decision needs

Outputs should include decisions, assigned actions, resources, and changes needed to the ISMS. Retain minutes or equivalent evidence.

16. Nonconformity and corrective action

- React and control the immediate issue.
- Correct the problem and address consequences.
- Determine root cause and whether similar issues exist elsewhere.
- Plan action proportionate to the effect.
- Implement action.
- Verify effectiveness after sufficient time.
- Update risks, controls, and documented information where needed.

Weak response: “Remind the employee.” **Stronger response:** identify why the process allowed failure, redesign the workflow, train affected roles, and verify the control operates effectively.

17. Certification readiness

- Select an accredited certification body and confirm scope and sector competence.
- Complete at least one internal-audit cycle and management review.
- Ensure risks, SoA, objectives, controls, and evidence are current.
- Close or formally manage major implementation gaps.
- Prepare personnel to explain their real responsibilities honestly.
- Understand Stage 1 normally evaluates readiness and documented design; Stage 2 evaluates implementation and effectiveness.
- Do not create or backdate evidence for an audit.

Common readiness failures

- Scope does not match operations.
- Risk register and SoA are disconnected.
- Controls are described but evidence is missing.
- Owners cannot explain responsibilities.
- Supplier and cloud risks are incomplete.
- Internal audit lacks independence or depth.
- Management review is a presentation without decisions.
- Corrective actions close without effectiveness verification.

18. 30/60/90-day roadmap

Days 1-30: establish the foundation

- Appoint sponsor and ISMS manager.
- Define implementation governance.
- Identify context, interested parties, obligations, and draft scope.
- Perform gap assessment.
- Approve risk method and document-control approach.
- Create the implementation register.

Days 31-60: assess and implement

- Complete risk assessment.
- Develop treatment plan and SoA.
- Assign control owners.
- Prioritize high-risk controls and legal obligations.
- Create essential policies and procedures.
- Begin recurring evidence collection and awareness.

Days 61-90: verify and improve

- Measure objectives and control operation.
- Complete internal audit.
- Correct significant gaps.
- Conduct management review.
- Verify corrective actions.
- Prepare a certification-readiness decision and longer-term improvement plan.

19. Templates and checklists

Minimum ISMS implementation checklist

- ☐ Context and interested parties documented
- ☐ Climate relevance considered
- ☐ Scope approved
- ☐ Policy approved
- ☐ Roles assigned
- ☐ Risk criteria approved
- ☐ Risk assessment completed
- ☐ Treatment plan approved
- ☐ SoA completed
- ☐ Objectives and metrics defined
- ☐ Required procedures operating
- ☐ Evidence retained
- ☐ Competence and awareness records available
- ☐ Internal audit completed

- ☐ Management review completed
- ☐ Corrective actions verified
- ☐ Certification scope and body confirmed

Risk register fields

Field	Purpose
Risk ID	Unique traceability.
Process or asset	Where the risk exists.
Threat and vulnerability	Cause or condition.
Consequence	Potential business or human effect.
Owner	Decision accountability.
Inherent rating	Before considering controls.
Existing controls	Current safeguards.
Residual rating	After existing controls.
Treatment	Action, owner, date, status.
Acceptance	Authorized residual-risk decision.

20. Glossary and official references

Term	Definition
ISMS	Information security management system.
SoA	Statement of Applicability.
Conformity	Fulfilment of a requirement.
Nonconformity	Non-fulfilment of a requirement.
Corrective action	Action to eliminate the cause of a nonconformity and prevent recurrence.
Residual risk	Risk remaining after controls.
Interested party	Person or organization that can affect, be affected by, or perceive itself affected by the ISMS.

[ISO/IEC 27001:2022 official page](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 official page](#)

[ISO/IEC 27000 family](#)

[ISO 19011 auditing guidance](#)

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0. ISO standards are copyrighted by ISO; obtain authorized copies from ISO or an authorized national standards body.